

# Model card: SavannaPay incident risk scorer (AICS-112)

Owner: Firdaws Alnuur Mohammed. Version 1.0. Synthetic classroom data only.

## 1. Intended use and prohibited use

**Intended use:** rank correlated candidate incidents (0 to 100) so an analyst sees the most urgent one first, and explain why. The score feeds notification and triage. It never executes containment on its own.

**Prohibited use:** - Deciding to isolate a host or disable an account without a named human approval. - Use on real production data. The weights were never trained or validated on real events. - Employee performance or disciplinary decisions. - Feeding the output to an AI model as an instruction.

## 2. Features and sources

Each feature is 0 or 1 per incident group (incident\_features in soar\_lab/pipeline.py).

| Feature             | Weight | Definition                                                                         | Source                   |
|---------------------|--------|------------------------------------------------------------------------------------|--------------------------|
| intercept           | -2.70  | baseline bias                                                                      | instructor               |
| ioc_match           | 2.35   | any event matched a STIX indicator                                                 | threat_intel_stix.json   |
| multi_source        | 1.25   | events come from 2 or more sources                                                 | event source field       |
| critical_asset      | 0.85   | asset criticality 4 or higher                                                      | assets.csv               |
| privileged_identity | 1.05   | any event by a privileged account                                                  | identities.csv           |
| malware_signal      | 1.75   | process_start, credential_access or file_quarantined, with max severity 60 or more | event types and severity |
| identity_anomaly    | 1.35   | mfa_method_added, oauth_consent, account_lockout, or 3 or more login failures      | event types              |
| exfil_signal        | 1.85   | a large_upload event                                                               | event types              |

Score = round( $100 \times (0.7 \times \text{probability} + 0.3 \times \text{max\_severity}/100)$ ), where probability =  $1 / (1 + e^{-z})$ ,  $z = \text{intercept} + \sum(\text{weight} \times \text{feature})$ .

## 3. Weight provenance

Instructor-supplied synthetic baseline. The weights were not learned from data by the student and not validated on real incidents.

## 4. Threshold and cost assumptions

Threshold experiment on training data (evidence/lab4\_threshold\_experiment.txt): - 30 and 40: 1 false positive (SOAR-0005, score 44), precision 0.89, recall 1.00. - 50, 65, 75, 85: 0 false positives, 0 false negatives.

Chosen policy: escalate at 65, notify analyst at 40, and always require named human approval for isolate\_endpoint and disable\_identity (score 85 and above).

Cost assumption: a false alert costs analyst minutes. A missed attack, or a wrongful account disablement, costs far more, so containment stays human-approved.

## 5. Limitations, bias risks and drift

- The training set holds one attack chain, so equal results at four thresholds are weak evidence. Re-test on the blind capstone data.
- Features are binary and rule-based. An attacker who avoids the listed event types lowers the score.
- Bias risk: critical\_asset and privileged\_identity raise scores for admins and finance staff, so their normal activity will be escalated more often. Review false positives by department.
- Drift indicators: rising false positives, share of incidents above 65, changes in event type mix, new attack techniques not in the feature list.
- The optional LLM (qwen3:4b) can hallucinate. In the SOAR-0001 test it was fluent and cited all 8 events correctly, but it overclaimed ("compromised") and returned a weak, repeated step list (see evidence/lab4\_comparison.md).

## 6. Human oversight, logging and rollback

- Every action is a dry run in this lab.
- The AI endpoint returns advice only. Isolate and disable need a named analyst (3 or more characters) and are recorded.
- Prompt-injection text is flagged and cleaned, and next steps must be on a fixed allowlist.
- Every decision is written to a hash-chained audit log (previous\_hash, record\_hash).
- Rollback: the model is deterministic, so reverting FEATURE\_WEIGHTS in git restores the earlier behavior. Idempotency keys stop repeated actions.